정보보안 기본정책

제정 2024.02.01. / 제1차 개정 2025.06.01. / 제2차 개정 2026.10.01.

제1장 총칙

제1조(목적)

회사의 정보자산과 정보시스템을 업무상 위협으로부터 보호하고 임직원·협력사·관리 부서의 책임과 준수기준을 정한다. 이 정책은 개인정보 관련 법령과 회사의 세부 지침을 대체하지 않는다.

제2조(적용범위)

회사가 소유·임차·관리하거나 업무 목적으로 이용하도록 승인한 시스템, 문서, 장비와 데이터를 대상으로 한다. 회사 정보에 접근하는 임직원, 파견·협력사 인력도 계약과 권한 범위에서 준수한다.

제3조(우선기준)

법령과 계약에서 강화된 보호조치를 요구하는 경우 이를 우선 적용한다. 일반적인 IT 이용 매뉴얼과 FAQ는 정책의 허용 범위를 확대할 수 없으며 해석 충돌은 정보보안팀이 검토한다.

제4조(용어)

정보자산은 회사의 문서·데이터·서비스·계정·장비를 포함한다. 정보자산 소유자는 업무상 분류와 접근 필요성을 판단하는 부서를, 기술 관리자는 승인 내용을 시스템에 적용하는 부서를 뜻한다.

제2장 관리 책임

제5조(정보자산 소유자)

각 부서장은 소관 문서와 시스템의 업무 목적, 공개범위, 보존 요건, 접근 가능 직무를 지정하고 정기적으로 재검토한다. 보안등급만으로 개인정보 처리의 적법성이 자동 확보되는 것은 아니다.

제6조(정보보안팀)

정보보안팀은 보호기준 수립·예외 심사·사고대응 통제와 권한 점검의 적정성을 관리한다. IT지원팀은 승인된 계정·장비·네트워크 정책의 기술적 실행과 처리기록을 관리한다.

제7조(사용자 의무)

임직원은 본인 계정을 사용하고 보안사고·분실·오발송을 알게 되면 즉시 지정된 신고 경로로 알린다. 조사 전에 증거를 임의로 지우거나 계정·기기 설정을 변경해서는 안 된다.

제8조(외부자 관리)

협력사에게는 계약기간, 대상 시스템, 작업 목적과 책임자를 지정하여 권한을 부여한다. 계약 종료 또는 담당자 변경 시 소관부서는 회수 요청을 지체 없이 제출한다.

제3장 보호조치

제9조(분류 및 보관)

문서와 데이터는 「정보자산 등급 분류 및 취급 지침」에 따라 분류한다. 등급별 보관·전송·출력 조건과 실제 개인정보 보호 요건은 모두 충족해야 한다.

제10조(인증과 권한)

개인별 계정, 필요한 범위의 권한, 지정된 인증수단을 원칙으로 한다. 관리자 권한과 외부 원격접속은 별도 승인 및 로그 검토 대상이며, 계정 발급·회수는 IT-041에 따른다.

제11조(정보 반출)

개인 메일, 외부 저장소, 이동식 매체, 생성형 AI 서비스 등으로 회사 자료를 보내려면 매체와 자료 등급에 따라 소관 승인 절차를 거친다. 통상 사용 허가는 기밀문서 반출 승인으로 보지 않는다.

제12조(사고·예외)

사고 징후는 즉시 보고하고, 임시 대응 조치는 사고대응 책임자의 통제 아래 수행한다. 기술적으로 통제가 어려운 업무 예외는 종료일과 대체 통제방법을 기록하여 사전 승인을 받는다.

제4장 점검과 시행

제13조(점검)

정보보안팀은 부서별 정책 준수와 위험 개선 과제를 점검하고, 부적합 사항의 담당자·조치기한·검증 결과를 기록한다. 점검 결과를 이유 없이 전사에 공개하지 않는다.

제14조(교육 및 개정)

보안교육의 대상·평가·미이수 처리는 ED-025 및 ED-024에 따른다. 개정 시 관리대장에 개정일과 변경 조항을 남기고 필요한 대상에게 공지한다.

업무 처리 기준 및 확인 사항

별표 1. 통제 책임 구분

업무	업무 책임	기술 처리 / 검토
문서 분류·공개범위	정보자산 소유부서	정보보안팀 검토
계정 발급·회수	시스템 소유자 승인	IT지원팀 실행

업무	업무 책임	기술 처리 / 검토
개인정보 취급	개인정보 처리부서	개인정보 보호책임 체계
보안사고	최초 발견 직원 즉시 신고	정보보안팀 지휘

부칙

제1조(시행일) 이 규정은 2026년 10월 01일부터 시행한다.